Informe de Correcciones de Seguridad

Auditoría OWASP ZAP — Aplicación Blazor Server (.NET Core)

APLICACIÓN	HERRAMIENTA	ESTADO DE AUDITORÍA
WebEmpresa (Blazor)	OWASP ZAP 2.17.0	Corregido & Optimizado

MATRIZ DE VULNERABILIDADES Y CORRECCIONES

ALERTA OWASP ZAP	SOLUCIÓN APLICADA EN CÓDIGO	ESTADO & JUSTIFICACIÓN
Reexaminar Directivas de Control de Caché	Agregadas cabeceras HTTP: `Cache- Control: no- store, no- cache, max- age=0, must- revalidate` `Pragma: no- cache` | `Expires: 0`	CORREGIDO Garantiza que información sensible no quede almacenada en caché local o proxies.
Cookie Sin Flag de Seguridad	Configuración global en servicios: `CookieSecurePolicy. Always SameSiteMode. Strict`	CORREGIDO Asegura que cookies de sesión/antiforgery viajen encriptadas en HTTPS.
Divulgación de Información (Server Header)	Middleware de respuesta: `context. Response. Headers. Remove(" Server");`	CORREGIDO Oculta la firma del servidor web para evitar perfilado de vulnerabilidades.
CSP: Directiva Wildcard / No Fallback	Definición estricta en CSP: `obj ect- src ' none' ; base- uri ' self' ; frame- ancestors ' self' ;`	MITIGADO Bloquea la inyección de objetos Flash/Java y previene ataques de enmarcado.
CSP: script-src / style-src (unsafe-inline/eval)	Mantenidos explícitamente en CSP por requerimiento técnico de Blazor.	REQUERIDO Necesario para la ejecución en tiempo real mediante SignalR/WebSockets.
Aplicación Web Moderna / Gestión Sesión	Reconocimiento automático de arquitectura SPA / WebSockets por ZAP.	INFORMATIVO Notificación del motor de análisis sobre tecnologías dinámicas

ANTES:
file:///C:/Users/josue/Desktop/WebEmpresa/2026-10-12-ZAP-Report-.html

DESPUES:
file:///C:/Users/josue/Desktop/WebEmpresa/2026-10-12-ZAP-Report-.html